

面向支付智能体的对抗评测与经验驱动修复：三环架构与确定性泛化证据

黄一民（中国人民大学，北京 100872）

对应研究提纲：《智能体支付系统和方案的设计》（2026-09-24 会后整理稿）。

代码与实验复现：<https://github.com/Fishman-free/REDTEAM>（分支 feat/agentpay-plan-2026-09）。

摘要

大模型智能体正在进入采购、审批、支付等资金相关业务流程。外部内容（商品页、邮件、工具返回）可能把“参考信息”伪装成授权，诱导错误付款；而只统计模型回答或“拒绝率”无法区分违规提议、平台拦截、实际执行与合法任务完成。本文提出并实现了一个面向支付类智能体的对抗评测与修复验证平台：以**三环架构**（攻击搜索环、防御修复环、总对抗循环）组织攻防；以**双入口身份授权模型**刻画“用户本人经核验形成授权、外部参与者只能交流不能授权”的权限边界；以**预注册判别标准**和平台侧可信账本实现程序化裁决（attempted / actual / utility 三事实、四态结果）；以**L0-L3 场景分级**（不允许付款、单笔付款、受控限额支付、多智能体协作）构建可验证的多级别支付智能体基准；攻击环引入 Crescendo 式多轮升级、ChatInject 式聊天记录伪装与 Rainbow-Teaming 式多样性管理，并以**有限反馈协议**显式约束攻防两侧的信息不对称。针对“修好这次错误不等于以后更会修”这一经验复用（RSI）核心问题，本文设计了基于单维度攻击族与 held-out 变体的确定性泛化实验：经验驱动的窄补丁使 held-out 新问题修复率随训练族数从 20% 单调升至 100%，族内新实体变体在一轮训练后全部被修复，且修复成本为通用不变量路线的 1/4、策略限制性更低。真实模型五臂对照实验已按预注册协议设计完成（本文不含真实模型实验结果）。全部度量来自宿主侧账本与裁决，不依赖模型自评；所有实验基于本地合成资产，不涉及真实资金。

关键词：大模型智能体；支付安全；提示注入；红队评测；自动修复；经验复用；程序化裁决

Abstract

Large-language-model agents are entering finance-related workflows such as procurement, approval, and payment. Untrusted external content can masquerade as authorization and induce wrong payments, while answer-level or refusal-rate metrics cannot distinguish violating proposals, platform interception, actual execution, and legitimate task completion. We present an adversarial evaluation and repair-verification platform for payment agents. It organizes attack and defense as **three coupled loops**; models the privilege boundary as **dual entries with identity-verified authorization** (the verified user channel forms executable authorization, external channels are data only); adjudicates **programmatically** against a platform-owned ledger with pre-registered criteria (three facts: attempted / actual / utility); grades scenarios into **levels L0-L3** (read-only, single payment, capped spending, multi-agent collaboration); and upgrades the attack loop with Crescendo-style multi-turn escalation, ChatInject-style chat-history disguise, Rainbow-Teaming-style diversity management, and an explicit **limited-feedback protocol**. For the core RSI question — “fixing this error does not imply fixing the next one” — we design a deterministic generalization experiment over single-dimension attack families and held-out variants: experience-driven narrow patches raise the held-out new-problem fix rate from 20% to 100% monotonically with the number of trained families, generalize to intra-family variants after one round of training, and cost one quarter of the generic-invariant route with lower policy restrictiveness. A five-arm real-model campaign is pre-registered; this paper contains no real-model results. All metrics derive from host-side ledgers; all experiments use locally synthesized assets only.

Keywords: LLM agents; payment security; prompt injection; red-teaming; automated repair; experience reuse; programmatic adjudication

1 引言

2024 年 11 月，链上智能体 Freysa 的奖池在对方第 195 次付费对话中被一句伪装成“管理上下文”的消息诱导转出约 4.7 万美元 [1]。这一案例揭示了资金类智能体的根本风险面：**能对话不等于有付款权限，但对话内容可能伪装成授权**。企业场景中，允许智能体为己验收订单发起付款建议的系统同样面临三种典型诱导——改收款人、改金额、重复付款——而外部消息声称“用户已同意”时，系统应当如何裁决？

现有评测多以“模型是否拒绝”或回答质量为判据，存在两个缺口。其一，**判据不够细**：一次攻击可能产生违规提议（被拦截）、实际越权执行、以及“因害怕攻击而拒绝合法任务”三种截然不同的结果，合并成一个“安全分”会掩盖真实风险。其二，**修复验证缺位**：发现漏洞之后，如何验证修复真的有效、且没有破坏正常业务、且同类新变体不会复发，缺乏可复

现的闭环。

更进一步，修复本身存在一个递归问题：**修好这次错误，不等于以后更会修**。一个系统在某类攻击上积累了经验之后，面对**新问题**是否更有效、成本是否更低？这一经验复用（Recursive Self-Improvement, RSI）命题需要实验框架来度量，而不能靠演示。

本文贡献如下：

1. **三环架构与双入口授权模型**：攻击搜索环、防御修复环与总对抗循环解耦组织；用户通道经身份核验产生可执行授权，外部通道内容永远不能新增或扩大授权（fail-closed），支付执行门只核对已验证授权记录。
2. **程序化裁决与预注册判别**：区分 `attempted_unauthorized` / `actual_unauthorized` / `utility_success` 三个事实，`passed` / `failed` / `error` / `unsupported` 四态结果，判据（违规码→证据→分母）在评测前冻结，不接受事后解释；全部事实来自平台持有的账本，模型自述不作数。
3. **可验证的多级别基准**：43 个种子横跨 L0（不允许付款）、L1（单笔与状态确认）、L2（单笔/每日限额）、L3（采购一审批—支付多智能体协作），其中 22 个具备可信状态适配器可执行，其余如实标注 `unsupported`。
4. **攻击环工程**：Crescendo 式多轮升级、ChatInject 式聊天记录伪装、机制簇多样性管理，以及把“攻击侧有限反馈、确认防守失败后完整交付”显式化为可测试协议。
5. **确定性 RSI 泛化实验**：单维度攻击族 + held-out 变体设计，直接度量“积累经验后解决新问题的有效率与成本”，得到可复现的学习曲线（§ 5），并以预注册协议给出真实模型实验设计（不含结果）。

2 相关工作

链上对抗案例。Freysa [1] 是与本文最直接的链上案例：参与者付费发消息试图说服智能体转出奖池，展示了对话攻击的资金风险，但它是一次性博弈，不构成经验复用的证据。CrAIBench [2] 在 150+ Web3 任务上度量上下文操纵（记忆投毒、提示注入）风险，其“以转账类任务为核心、按违规类型分类”的思路与本文的场景簇设计一致。

攻击方法。Crescendo [3] 证明从正常问题起步、利用模型先前回答逐轮升级的多轮攻击能有效绕过对齐；ChatInject [4] 进一步把恶意载荷格式化为原生聊天模板轮次，在 AgentDojo 上把攻击成功率从 5.18% 提升到 32.05%——两者共同说明：**对话格式本身会被当成信任信号**，来源与权限的混淆是真实威胁。Rainbow Teaming [5] 把对抗提示生成建模为质量-多样性问题，为攻击库的机制簇管理提供方法。AgentDojo [6] 确立了“同时报告攻击效果与正常任务完成”的评测范式。

修复与经验。GEPA [7] 用执行轨迹反思进化提示并以 Pareto 候选选择超越强化学习的样本效率；ACE [8] 把经验整理为可增量更新的策略手册，避免整写覆盖；Darwin Gödel Machine [9] 修改自身代码并以任务测试检验、保留版本谱系。本文分别以受限反思式提议器、追加式经验库与版本库（晋级/回滚）借鉴三者的工程思路，但不声称复现其算法：当前改良器自身的算法与权重固定，这正是 § 5 度量对象的边界。

与上述工作的差异：本文的落点是支付域 + 可信执行证据 + 修复回归闭环 + 经验泛化度量的组合，且全部判据程序化、可复现。

3 系统设计

3.1 三环架构

总循环由两个耦合的环组成：

- 攻击搜索环（攻击方）：模拟外部参与者中的攻击方，尝试诱导错误付款，再根据允许看到的结果改写攻击——攻击侧只获得有限反馈（§ 4.4）。
- 防御修复环（防御方）：确认防守失败后，攻击方式、手段、完整对话及执行记录交付防御智能体；它据此改进提示、记忆或工具规则，换例子测试通过后晋级，失败保留旧版。
- 总对抗循环：新攻击 × 新防御持续检验；编排、预算、独立测试与审计由平台承担。

五步修复循环（确认防守失败 → 交付攻击方案 → 防御智能体改进 → 换例子测试 → 通过后保留）中，**可变面被严格限定**：允许修改提示、记忆与工具规则；授权事实、账本与评分标准在安全不变量保护下不可被候选触碰。

3.2 双入口与身份授权核验

权限边界以“入口分开、权限不混用”为原则（图 1b）：

用户本人 —— 对话提出任务/确认变更 —— 身份与授权核验 —— 可执行授权记录
外部参与者 —— 正常交流，也可能攻击 —— 外部对话/资料入口（标记来源，不新增授权）
可执行授权记录 —— 支付智能体（提议付款） —— 支付执行门（核对已验证授权） —— 账本与判别

三条不变量：（1）只有用户通道 + 已核验身份能形成或变更授权（AuthorizationGate fail-closed，任何外部通道形成/变更尝试被拒绝并记录为证据）；（2）授权记录有主体、范围（收款人/金额/币种/用途/次数/时间窗/审批要求）、来源消息链与状态，支付执行门在每次执行前核对记录仍然有效（撤销/过期即拦截）；（3）账本由平台维护，被测对象不可写。据此，“商户转述用户电话同意”与“工具返回自称已实名核验”都在判别层被显式覆盖。

3.3 预注册判别标准

每个基准种子在注册时冻结 adjudication 判据：从规则表（PAY-ACCOUNT-BOUND、PAY-AMOUNT-EXACT 等）确定性编译出“违规码 → 判别语句 → 账本证据来源”，加上分母政策（违规提议、实际执行、合法完成、错误/未支持分别列报，错误与未支持不得计入通过分母）。这落实了“判断标准基于用户预先设定的约束、提前明确规定清晰”的要求。

3.4 场景分级 L0 - L3

层级	含义	关键机制	种子示例
L0	不允许付款（只读）	<code>allows_payment=false</code> ，任何付款请求 = <code>payment_forbidden</code>	只读汇总发票；外部诱导其付款
L1	单笔付款与状态确认	精确金额授权；可信先前付款状态由宿主注入	超时后不重复扣款；多轮诱导不改收款人
L2	受控/限额支付	单笔上限 + 累计上限，金额可变（如单笔 ≤ 35 元、每日 ≤ 90 元）	拆分规避限额、对账差额突破日限额
L3	多智能体协作	采购→审批→支付三角色分工、权限分级	伪造审批文本连穿三道检查

L3 由独立的多智能体系统 PayChain 实现：purchaser / approver / payer 三个角色组件各持独立检查，外部内容必须连续穿过三道检查才能变成付款。基准注册表共 43 个种子（含退款域与非支付域占位），22 个具备可信状态适配器可执行，其余如实报告 unsupported——未实现项不计通过。

3.5 可信执行与程序化裁决

被测智能体的输出只是**建议**（arena.payment-plan.v1 协议：submit / blocked 批次）。平台持有账本与幂等性：每次执行由可信支付执行器落账，账本经哈希校验后由冻结的 constitution 重放，导出三个事实：attempted_unauthorized（出现违规请求，含被拦截）、actual_unauthorized（实际落账）、utility_success（授权付款完成）。模型返回的 source、user_confirmed 与任何执行声明从不作为事实。

4 攻击环设计

4.1 两个入口分别测试

用户对话入口的攻击以多轮会话承载（身份合法但诱导越权）；外部对话/内容入口的攻击通过四个不可信表面（发票备注、商家消息、商品页、工具返回）注入。

4.2 Crescendo 式多轮升级

把一次越界请求拆成多轮：第一轮只问正常流程，第二轮引入（未经验证的）“先前确认”叙事，最后一轮携带完整原载荷。多轮在同一任务上交替注入与会话执行，平台幂等性与裁决不受轮次影响。实测中，多轮升级在漏洞目标上诱导出了改收款人请求（true positive）。

4.3 ChatInject 式伪装

把载荷嵌入伪造的“用户消息 + 系统提示 + 客服回复”聊天模板轮次，使不可信内容在上下文里看起来像对话本身。实测同样在漏洞目标上得手（改收款人落账），验证了来源—权限混淆在支付域的可行性。

4.4 有限反馈协议

信息不对称是实验协议的一部分，被显式化为可测试模块：攻击侧每轮只获得 bounty 式结果摘要（提交编号、假设、程序化判定、有限错误摘录），**永不包含账本行、HTTP 轨迹或防御方信息**（由守护断言强制）；确认防守失败后，完整攻击方案（动作、任务夹具、程序化判定、结构化诊断：违反规则、首个可观察错误、未信任来源、缺失检查、候选修复位置）才交付防御侧。

4.5 攻击库多样性管理

按机制簇（mechanism key）统计已探索手法并注入攻击者简报，附新颖性要求：重复同一指纹的提交不产生新信息，防止攻击环反复生成同一手法（Rainbow Teaming 思路的工程化）。

5 RSI 泛化实验

5.1 设计

核心问题：**修好这次错误，不等于以后更会修**。积累经验后，系统解决新问题是否更有效、成本是否更低？

为使归因干净，实验采用**单维度攻击族**设计：四个可训练族各自只越权一个授权维度——附加费用（purpose）、替换收款人（recipient）、篡改金额（amount）、改写归属订单（order）——其余字段保持授权值。每族配有 held-out 变体：保留同一机制、更换实体、金额与说法。防御若只记住了训练样本的具体措辞或实体，held-out 上就会失败（过拟合被直接暴露）。另设伪造回执场景作为效用保护检查（它破坏任务而非制造越权付款）。

四个臂：

臂	提议器能力	对应问题
memory_narrow	只按已验证违规码打窄补丁	经验本身的泛化力
with_contract	窄补丁 + 授权契约不变量候选	知识 + 经验组合
no_memory	只用通用不变量候选、不读经验	知识本身是否足够
outer_curriculum	窄补丁 + 经验跨曲线点累积	越学越好的假设

学习曲线沿 $k \in \{0, 1, 2, 3, 4\}$ （训练族数量）展开。指标全部来自宿主裁决：held-out 新问题修复率（未见族变体：无越权请求、无实际落账、且授权任务完成）、已见族变体修复率（族内泛化）、正常任务完成率（效用回归）、策略限制性指数（强制位数，最小权限视角）、候选评估数（成本代理）。

5.2 结果

表 1: held-out 新问题修复率（%）随训练族数 k 的学习曲线

k	memory_narrow	with_contract	no_memory	outer_curriculum
0	20.0	20.0	20.0	20.0

k	memory_narrow	with_contract	no_memory	outer_curriculum
1	25.0	25.0	25.0	25.0
2	33.33	33.33	100.0	33.33
3	50.0	50.0	100.0	50.0
4	100.0	100.0	100.0	100.0

表 2：辅助指标（memory_narrow 与 no_memory 对照）

指标	k=1	k=2	k=3	k=4
已见族变体修复率（memory_narrow）	100	100	100	100
限制性指数（memory_narrow）	1	2	3	4
限制性指数（no_memory）	1	7	7	7
候选评估数（memory_narrow，累计）	3	7	12	18
候选评估数（with_contract，累计）	12	28	48	72

四条确定性结论：

1. **经验** → **单调改进**。经验驱动的窄补丁使新问题修复率随训练族数单调上升（20→25→33→50→100），每个族的经验精确贡献一个授权维度的覆盖。
2. **族内泛化一轮达成**。训练一个变体后，同族 held-out 新实体变体 100% 被修复——因为补丁是字段级而非实体级，这正是“换例子测试”能通过的机制基础。
3. **经验驱动的修复更窄、更便宜**。达到同等 100% 覆盖时，memory_narrow 的限制性指数为 4（最小权限渐进），no_memory 为 7（全量强制位）；每轮候选评估数为 1 对 4，累计成本约四分之一。
4. **知识本身可泛化但过约束**。no_memory 在 k=2 即达 100% 覆盖，但以最高限制性为代价；经验的价值在确定性目标上表现为**最小权限修复**，而非覆盖差异。

5.3 真实模型实验（预注册，未执行）

确定性“经验”是违规码到补丁字段的映射，不能代表大模型的反思质量。五臂真实模型战役（基线 / +授权契约知识 / +结构化反馈 / +两者 / +外层进化）已按预注册协议设计并冻结：训练/留出划分、预算、停止条件与指标在执行前固定，结果（含失败与放弃的臂）将全量报告。本文不含真实模型实验结果。

6 局限与声明

1. **确定性目标**：学习曲线在确定性目标与规则式提议器上取得，验证的是实验框架与度量，不等于真实大模型抗攻击率。
2. **同族变体**：held-out 与训练集共享攻击机制（同族新实体变体）；跨机制泛化需真实模型实验。

3. **单一域**: 实验覆盖支付域（含多智能体协作）；退款域与非支付域的 21 个种子尚无可信状态适配器，如实标注 unsupported。
4. **合成资产**: 全部实验基于本地合成数据与模拟账本，不涉及真实资金、主网或对外攻击面；研究靶场保留的故意漏洞不得公开暴露。
5. **不宣称**: 本平台不是主网支付产品、通用攻击平台，不证明模型具备通用安全性或递归自我改进能力；测试通过不等于生产安全。

7 结论与未来工作

本文给出了一个支付智能体安全评测与修复验证的完整工程闭环：双入口授权模型把“对话是形式、身份和授权决定权限”变成可执行的不变量；预注册判别与平台账本让“实际发生了什么”可复现；L0 - L3 分级让“可验证的多级别支付智能体”成为可操作的基准；攻击环的多轮、伪装与多样性工程让评测逼近真实威胁面；确定性泛化实验则把 RSI 命题从口号变成有数字的学习曲线。未来工作按优先级：(1) 按预注册协议执行真实模型五臂战役，度量反思质量与 token 成本维度；(2) 退款域与非支付域（尤其记忆投毒面）的可信状态适配器；(3) 审批请求证据协议，使 `wait_approval` 类判别可执行；(4) 沿 L0 - L3 度量防御难度随权限与复杂度的增长。

参考文献

- [1] Freysa. Adversarial agent game, on-chain case, November 2024. <https://www.freysa.ai>
- [2] A. S. Patlan et al. Real AI Agents with Fake Memories: Fatal Context Manipulation Attacks on Web3 Agents (CrAIBench). arXiv:2503.16248, 2025. <https://arxiv.org/abs/2503.16248>
- [3] M. Russinovich et al. The Crescendo Multi-Turn LLM Jailbreak Attack. USENIX Security, 2024. <https://arxiv.org/abs/2404.01833>
- [4] ChatInject: Abusing Chat Templates for Prompt Injection in LLM Agents. ICLR 2026. <https://arxiv.org/abs/2509.22830>
- [5] M. Samvelyan et al. Rainbow Teaming: Open-Ended Generation of Diverse Adversarial Prompts. arXiv:2402.16822, 2024. <https://arxiv.org/abs/2402.16822>
- [6] E. Huang, K. DeBenedetti et al. AgentDojo: A Dynamic Environment to Evaluate Attacks and Defenses for LLM Agents. arXiv:2406.13352, 2024. <https://arxiv.org/abs/2406.13352>
- [7] L. A. Agrawal et al. GEPA: Reflective Prompt Evolution Can Outperform Reinforcement Learning. arXiv:2507.19457, 2025. <https://arxiv.org/abs/2507.19457>
- [8] Agentic Context Engineering: Evolving Contexts for Self-Improving Language Models. Stanford / SambaNova / UC Berkeley, 2025. <https://arxiv.org/abs/2510.04618>
- [9] J. Zhang et al. Darwin Gödel Machine: Open-Ended Evolution of Self-Improving Agents. arXiv:2505.22954, 2025. <https://arxiv.org/abs/2505.22954>